Information Security Policy

Version 4.0 · Approved by the CISO

1. Purpose

This policy sets the minimum security requirements for all Brightline Analytics systems and staff. It applies to employees, contractors and any service that processes company or customer data.

2. Access control

Access is granted on the principle of least privilege. Managers review the access rights of their team every quarter. Accounts of people who leave the company are disabled within 24 hours.

3. Authentication

Multi-factor authentication (MFA) is mandatory for all administrator accounts and for remote access. Passwords must be at least 14 characters long. Shared accounts are not permitted.

4. API security

All APIs must authenticate every request. Internal services must use signed requests, and secrets must be rotated at least every 90 days. API keys must never be stored in source code.

5. Data classification

Data is classified as Public, Internal, Confidential or Restricted. Customer data is Confidential by default. Restricted data must be encrypted at rest and in transit.

6. Logging and monitoring

Security-relevant events, including logins, permission changes and data exports, must be logged. Logs are kept for at least 12 months and reviewed weekly by the security team.

7. Incident response

Suspected security incidents must be reported to security@brightline.example within one hour of discovery. The security team classifies the incident and leads the response.

8. Exceptions

Exceptions to this policy require written approval from the Chief Information Security Officer and are valid for a maximum of six months.